

Patching auto-complete vulnerabilities not enough, Cookie Eviction to the rescue

Patching auto-complete vulnerabilities not enough, Cookie Eviction to the rescue - Author not stated, blog.jeremiahgrossman.com.

- Published: date not stated
- Original: <<https://jeremiahgrossman.blogspot.com/2010/07/patching-auto-complete-vulnerabilities.html>>
- Current location: <<https://blog.jeremiahgrossman.com/2010/07/patching-auto-complete-vulnerabilities.html>>
- Preserved from: <https://blog.jeremiahgrossman.com/2010/07/patching-auto-complete-vulnerabilities.html> (live) on 2026-08-06
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Top 10 Web Hacking Techniques lists, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Let's say a bad guy was aware of the [Safari v4/5](#) and Internet Explorer v6/7 auto-complete vulnerabilities before public disclosure occurred or patches were made available (such as it is right now). They might want to maintain the ability to identify Web visitors even if they disabled form auto-complete or fixed the bug. All the bad guy would have to do is mass distribute their auto-complete code, like on an advertising network or a series of malware infected pages, obtain their victims personal information (name, email, address, etc.) and cookie them with a ID (i.e. domain = <http://whoisthisperson/>). When the person returns, even in a patched or feature disabled state, their browser (or the cookies within) would silently give up their identity.

Taken one step further, this identification system could be setup as a Web Service for other websites to take advantage of. Theoretically, if a website owner wanted to know precisely who their visitor is they would include a third-party javascript WebWidget similar to the following.

```
DOMAIN: http://website/ <* script> function identify (person) { // do something with the persons data }
<* /script> <* script src="http://whoisthisperson/?callback=identify"> <* /script>
```

When the cross-domain request is made to <http://whoisthisperson/> the persons cookie ID that identifies them automatically goes with it. Standard Web tacking/bug behavior. If the data is available, the persons information returns within a JSON object and loaded into the previously defined callback function.

```
DOMAIN: http://whoisthisperson/ var person = { name: 'name', email: 'name', } identify(person);
```

The result is a long-term auto-complete problem. Unless exposed users go out of their way to delete their cookies voluntarily, flash cookies and off-domain storage included, they can't be certain their identity isn't being shared with every site they visit. To be fair, there is no evidence that form auto-complete vulnerabilities have been actively exploited in the wild or that any such system has been established. Still for those of us who take a paranoid interest in Web security, we can keep an eye out since we know what to look for. The thought crossed my mind that maybe there is a way for a "benevolent" website to forcibly remove all of a visiting browser's cookies across all domains. It turns out, there is.

Everything has a limit. That includes the total number of cookies a Web browser will store. For Firefox that number is 3,000. Chrome and Safari 3,500. Also take note that each hostname can set 50 cookies. The interesting part is once the browser's global cookie cap has been reached, older cookies get evicted -- that is they are deleted to make room for new ones. An [issue known by Mozilla](#) and [discussed periodically by others](#). Using just a single domain name (i.e. foo.com), 70 unique hostnames on that domain (i.e. 1.foo.com, 2.foo.com, etc.), each hostname setting 50 cookies, the global cookie limit can be reached in just a few seconds. Visiting Web browsers will essentially have all their cookies from all the other domains evicted. That includes session cookies, tracking cookies, and even auto-complete identification cookies should they exist. One can think of this like a generic global logout of sorts.

The following code is the most performance enhanced way I've found to perform cookie eviction.

Landing Page on <http://www.foo.com/> Setup wildcard DNS to make things easy.

```
<* script> for (var i = 1; i <= 70; i++) { img = new Image(); img.src = "http://" + i +  
".foo.com/addcookie?"; } <*/script>
```

Each image object will execute this perl script to load-up 50 cookies

```
#!/usr/local/bin/perl -w use strict;
```

```
print "P3P: CP=\"IDC DSP COR ADM DEVi TAIi PSA PSD IVAi IVDi CONi HIS OUR IND CNT\";\n"; print  
"Set-Cookie: cname_1=_cvalue1;\n"; print "Set-Cookie: cname_2=_cvalue2;\n"; print "Set-Cookie:  
cname_3=_cvalue3;\n";
```

... to 50

It is really just that simple. Check out the video.